

KeyQuorum

Manual

Bailey Forbes

A manual for the KeyQuorum hardware-key quorum file-sharing system: hardware keys and devices, split-tree quorum protection, private sign bridges, authenticated updates, moving identities between devices, sending files directly, and the mailbox relay that connects machines that are not open together.

Contents

1 Overview	1
1.1 Concept	1
1.2 What this manual covers	1
1.3 Status	1
1.4 Browser lab	1
2 Getting started	2
2.1 Building the CLI	2
2.2 The local database	2
2.3 Two kinds of identity	2
3 Hardware keys	2
4 Devices and custody	3
4.1 Presenting a slot	3
4.2 Custody modes	4
4.3 Parent approval	4
5 Splitting a secret	4
5.1 A two-department example	5
5.2 Growing and rebinding a tree	5
5.3 Bridges (whitelist and pairing)	5
5.4 Publishing and fetching topology	6
6 Hierarchical principals	6
6.1 What a hierarchical principal is	6
6.2 Four dimensions, four owners	6
6.3 A worked example	7
7 Quorum-protected files	8
7.1 Expiry	8
7.2 Verbose unlock	8
8 Password-protected files and credentials	8
9 Signatures, export, and sharing	9
10 Private sign bridges	9
10.1 Envelope shape	10
10.2 Revocation and rotation	10
10.3 Evicting a hardware key	11
11 Authenticated updates: reissue and restructure	11
11.1 The four-part authorization rule	11

11.2	What a reissue changes	12
11.3	Restructure vs. publish	12
12	Moving a key between devices	13
12.1	Package format and audit	13
12.2	Transferring through the mailbox	13
13	Sending a file	14
14	The mailbox relay	15
14.1	The device mailbox	15
14.2	Recovering from a lost key or a missed pull	15
15	Security model	16
15.1	What the mailbox can and cannot see	16
15.2	Custody, quorum, and delegation, at a glance	16
15.3	Envelopes and authenticity	16
16	File formats quick reference	16
16.1	Roadmap	17
17	Contributing	17
18	License	17

1 Overview

KeyQuorum is a secure file-sharing system centered on hardware key sharing. Files are encrypted and bound to registered physical tokens, such as USB devices. Access requires the necessary hardware keys to be presented before a protected file can be unlocked, providing layered, hardware-backed access control.

Note

This physical binding depends on a key actually being placed in a `keyquorum-device` container (Section 4). An unplaced `-share-file` key file is classified by its own key identity: two such files can both count toward `minimum_physical_devices` even while sitting on the same physical drive, since nothing ties either one to a container's `device_id`.

1.1 Concept

- A **key** — the data key protecting a file, or a secret split for its own sake — can be divided recursively: split into parts, any of which can itself be split further, forming a tree. A company master key can split across departments, and one department's own share can split again across its team. A flat “*M*-of-*N* hardware keys” quorum is just the simplest one-level tree.
- **Unlocking** a protected file means reconstructing its key's tree: presenting a quorum of the registered keys, rather than a single token or password.
- The goal is layered, hardware-backed access control that resists single-point compromise. A lost or stolen key alone should not be enough to unlock protected data.

1.2 What this manual covers

This manual documents the `keyquorum` and `keyquorum-device` command-line tools: generating and registering hardware keys, building and reconstructing quorum trees, protecting files and credentials, private signing bridges, authenticated updates to a live tree, moving identities between physical devices, sending files directly to another person, and the mailbox relay that carries all of the above between machines that are not open at the same time.

Note

Passwords, PINs, and hardware-key material are always prompted for interactively, or read from a `-share-file` key path, rather than taken as plain command-line arguments. This keeps secrets out of shell history and process listings.

1.3 Status

The CLI covers most of what this manual describes. Hardware-key quorum splitting and reconstruction are implemented in software: a key file with no container placement is still one device, several identities can share one container, a non-root tree restructure waits for its parent to countersign, and `transfer copy` / `transfer move` carry an active identity to a second device that is open at the same time, or through the mailbox as a sealed letter when it is not.

Two things remain outside the current scope: persisted private-key custody beyond a key file or a `keyquorum-device` container (for example an OS keychain), and `import` of password-vault or locked-file `export` bundles (the bundle format itself is final; private-bridge `.kqpb` import is already implemented).

1.4 Browser lab

KeyQuorum Lab runs this crate in a browser as a small sandboxed machine, compiled to WebAssembly. It has its own files, a SQLite store per person, mock USB drives, and a relay answering in the page. Every button and every terminal line runs the real `keyquorum` and `keyquorum-device` commands, so the lab demonstrates the same behavior described in this manual — with published demo passphrases, so it is not hardware-backed security. It is a good place to try the command sequences in this manual without provisioning real hardware.

Note

The lab's own GUI — its tabs, the Active user bar, and its guided in-browser tutorials — is documented separately in the *KeyQuorum Lab* manual, not in this one. This manual covers the `keyquorum` / `keyquorum-device` CLI itself, which the lab runs underneath its interface unchanged.

2 Getting started

2.1 Building the CLI

Build the customer CLI with a release build; the binary is `target/release/keyquorum`.

```
cargo build --release
```

Adding `-features provider` compiles mailbox-host capabilities into the same crate. That flag is a build capability, not authorization: official clients trust a relay only when it presents a KeyQuorum-signed provider certificate and proves possession of the matching private key. This manual covers the customer-facing surface — the URL and API key a provider gives you, and the `loadkey` / `relay push` / `relay pull` commands built on top of them. Run `keyquorum -help` for the full, current command list; this manual explains what each area of that list is for and how the pieces fit together.

2.2 The local database

Most commands read and write a local SQLite database that holds your split trees, registered keys, and (for a relay-connected identity) a sealed copy of your mailbox bearer. Pass `-db` to point at a specific file; when omitted, commands use a default database in the current directory. Running the same commands against different `-db` files is how one machine can hold several independent identities (for example `alice.sqlite` and `bob.sqlite` in the walkthroughs throughout this manual).

Security

Never commit a SQLite database, a private key file, an API bearer, a provider certificate, a revocation list, a device descriptor (`device.kq`, `device.skey`), or a slot token (`*.kqst`) to version control. See `.gitignore` for the patterns this repository already excludes.

2.3 Two kinds of identity

KeyQuorum draws a line between two things that both use the word “key”:

- A **hardware key** is a registered Ed25519/X25519 keypair, generated with `keyquorum generate` or brought in with `keyquorum register`. It is what a person, device, or slot presents to satisfy a quorum, sign a message, or open a sealed envelope.
- A **split key** (or “key” in `split` / `tree` output) is the secret being protected — a standalone escrow, or the data key encrypting a specific file. It lives as a tree of leaves, each leaf sealed to one hardware key.

The rest of this manual moves through the CLI roughly in the order you would use it for a new deployment: registering hardware keys and devices, building a split tree, protecting files and credentials against it, then the supporting machinery — private sign bridges, authenticated updates, device transfer, direct file delivery, and the mailbox relay that connects machines that are not open together.

3 Hardware keys

Hardware and tree verbs are top-level commands (`generate`, `split`, `bind`, and so on).

```
# Generate a keypair. The private key is printed to stdout ONCE and never
# written to disk by this tool -- redirect it yourself. Since the shell,
# not keyquorum, creates that redirected file, set a restrictive umask
```

```
# first so it is not created world- or group-readable.
umask 077
keyquorum generate --type encryption --public-key-out alice.pub \
  --label alice --register > alice.key
keyquorum register --type encryption --label bob --public-key-file bob.pub
keyquorum list
```

Security

A file created by shell redirection (`> alice.key`) gets whatever permissions your shell's `umask` allows — `keyquorum` never writes to it and cannot restrict it after the fact. Always set a restrictive `umask` (or move the file into owner-only permissions yourself) before redirecting a generated private key to disk. This applies to every `generate ... > key-file` line in this manual, not only this one.

`generate -register` writes the public key and records it in one step. `register` brings in a public key that already exists elsewhere (a PEM or OpenSSH file, or another person's `.pub`) under a chosen label. `list` shows every registered hardware key and every live split tree.

Note

Two key types are used throughout this manual: `-type encryption` keys unwrap sealed shares and envelopes; `-type signing` keys produce and verify Ed25519 signatures (private bridges, `sign` / `verify`, authenticated updates). A label commonly needs both — an encryption key to receive things, and a signing key to authorize or countersign them.

4 Devices and custody

A key file with no container placement is its own device. Distinct `-share-file` keys count as distinct physical devices, including when `minimum_physical_devices` is greater than 1. Presenting the same key twice still counts once.

`keyquorum-device` manages the container directory. `keyquorum device` registers a slot's public key in the org store and binds it to the opened container. Several identities can live as passphrase-wrapped slots in one directory (a mounted USB, or a stand-in). The directory is an index: `device.kq` (KQDV v2) is signed by `device.skey`, and each slot token (`*.kqst`, KQST) seals that same device id. Opening a slot checks the token against the descriptor, so a rewritten descriptor id cannot make one container count as two devices. Path, mount, and volume label are *not* the device identity — `relocate` moves a slot's keypair onto another container, and that is the authenticated change of `device_id`.

```
keyquorum-device init ./usb
keyquorum-device provision ./usb --label M.S
keyquorum-device list ./usb
keyquorum device register ./usb --slot M.S --type encryption
keyquorum device bind ./usb --slot M.S
keyquorum-device relocate --from ./usb --to ./usb2 --label M.S
```

`register` records the public key; a lone key file still uses `register` and `-share-file`. `bind` writes the placement from the container this process opened, tying that key to the container's `device_id`.

4.1 Presenting a slot

Commands that unwrap a key also take `-slot container=label` beside `-share-file`. This includes `reconstruct`, `add`, `bind`, `revoke`, an access quorum `unlock`, `bridge private import`, `sign`, `remove-member`, and `relay pull`. `tree countersign` takes `-device` and `-slot` instead.

```
keyquorum reconstruct <key-id> --slot ./usb=M.S --slot ./usb2=M.A \
  --output master.pub
keyquorum --db alice.sqlite relay pull --import --slot ./usb=M.S
```

4.2 Custody modes

`split`, `tree`, and `access quorum` `-state 0` set `-custody` (hardware or logical) and `-minimum-physical-devices`.

- **Hardware** custody requires each share Shamir actually consumes to sit on its own device id.
- **Logical** custody lets several slots on one container meet that Shamir threshold together; the container still counts as one device toward the minimum. Logical mode is for development and constrained hardware — logical slots are not a hardware quorum.

Reconstruction searches threshold-sized subsets for one that meets `minimum_physical_devices`. Unused extra shares are not counted.

```
keyquorum split --label master --threshold 2 --custody logical \
--minimum-physical-devices 2 \
--leaf M.S=SoftwareDepartment.pub --leaf M.A=AccountingDepartment.pub \
--source master.pub --generate-keys --register
keyquorum tree <key-id> --custody hardware --minimum-physical-devices 2
```

4.3 Parent approval

`unlock_approval` is `none` (the default) or `parent`. Parent approval is opt-in and sits on top of both Shamir and the device count: each leaf that contributed a share needs its direct parent's signature.

```
# The leaf's own key, and a registered *signing* key for its direct
# parent M.S -- the approval check verifies against that registration.
keyquorum generate --type encryption --label M.S.1 --register \
--public-key-out m-s-1.pub > m-s-1.key
keyquorum generate --type signing --label M.S --register \
--public-key-out M.S.sign.pub > M.S.sign.key

keyquorum access quorum --state 0 --source ./secret.txt \
--encrypted-path ./secret.txt.kqenc \
--leaf M.S.1=m-s-1.pub --threshold 1 --unlock-approval parent
keyquorum access quorum --state 1 --id <file-id> --share-file m-s-1.key \
--approve "M.S.1=M.S.sign.key"
```

`-approve` takes either `leaf=signing-key-file` or `leaf=container>slot`.

5 Splitting a secret

Splitting is how a standalone secret is escrowed, and how a file's data key is protected — both use the same tree machinery.

Note

The live SQLite tree *is* the spec for whoever holds that store. An operator or publisher may keep the full org tree; a personal store should hold only the nodes that person needs for signing and access control: their lineage, their descendants, siblings of their node, and the fixpoint of *established* bridge peers (the peer and the peer's ancestors, not the peer's unrelated siblings). Pushing from a personal store merges that subgraph into the relay; it does not replace the canonical document. There is no JSON file to author by hand — `split`, `bind`, `add`, `revoke`, `bridge`, and `access quorum -state 0 -leaf` write the tree in place. `tree -output` writes a snapshot of whatever is stored now; `-tree-spec FILE` remains only for a nested one-shot tree.

Labels must be unique within a tree. `tree <id> -node A B` prints that set's lowest common ancestor; `reconstruct -node A B` starts recovery at that ancestor. `tree` with no id lists every stored spec.

5.1 A two-department example

`split` `-source` `master.pub` escrows that key file (hex, PEM, or OpenSSH). `-leaf` builds a one-level tree and binds every sibling pair, so `M.S <-> M.A` is recorded even after a later refresh. Reconstruct with the holders' key files and `-output`. A 2-of-2 department tree (`M = master.pub`, `M.S = SoftwareDepartment.pub`, `M.A = AccountingDepartment.pub`) reassembles the master from the two department keys:

```
keyquorum split --label master --threshold 2 \
  --leaf M.S=SoftwareDepartment.pub --leaf M.A=AccountingDepartment.pub \
  --source master.pub --generate-keys --register
keyquorum reconstruct <key-id> \
  --share-file SoftwareDepartment.pub --share-file AccountingDepartment.pub \
  --output master.pub
keyquorum tree
keyquorum tree <key-id> --output org.json
```

`-generate-keys` creates each leaf's `.pub` / `.key` pair; `-register` records those public keys. Dotted leaf labels (`M.S`, `M.A`) infer the root node `M`. `-bind M.S=M.A` adds an extra pairing; `-leaf` already binds sibling leaves. A `.pub` share file uses the sibling `.key` (or a private-key prompt) to unwrap that department's sealed share — both departments are required because `M`'s threshold is 2.

5.2 Growing and rebinding a tree

Later commands keep changing the same tree. Pairings are stored by node id, so they survive a secret refresh, a new leaf, or a leaf moving to a new public key:

```
# Pair two nodes (whitelist both ways + establish the link)
keyquorum bind <key-id> --node M.S --peer M.A

# Move M.S onto a new token; node id -- and the bind -- stay put
keyquorum bind <key-id> --node M.S \
  --public-key-file NewSoftware.pub --share-file SoftwareDepartment.key \
  --register

# Grow M to 2-of-3; survivor node ids (and M.S <-> M.A) stay put
keyquorum add <key-id> --parent M --node M.F \
  --public-key-file FinanceDepartment.pub \
  --share-file SoftwareDepartment.pub --share-file AccountingDepartment.pub \
  --generate-keys --register
```

5.3 Bridges (whitelist and pairing)

```
keyquorum tree 1 --node alice bob
keyquorum reconstruct 1 --node alice bob --share-file alice.pub \
  --share-file bob.key
keyquorum bridge allow 1 --node alice --peer it
keyquorum bridge add 1 --from alice --to it
keyquorum bridge list 1
keyquorum bridge remove 1 --from alice --to it
keyquorum bridge deny 1 --node alice --peer it
```

`bind -peer` is the usual way to stand up `A <-> B`. `bridge allow` / `deny` change the whitelist only. `bridge add` / `remove` stand up or tear down an established pairing — `add` requires a whitelist hit on either side; `deny` also drops any pairing.

Note

This bridge/whitelist pairing is unrelated to a *private sign bridge* (Section 10), which is a separate, N-person co-signing group.

5.4 Publishing and fetching topology

The relay stores the **full** public tree as a JSON document. Sending data (**relay push**, including private-bridge envelopes) merges the sender's public topology into that document; nodes the sender does not hold stay in place, so a personal subgraph cannot replace canonical context. Fetching data (**relay pull**) returns the slice this device's encryption fingerprint is allowed to see, and the CLI merges it into local SQLite before importing envelopes. A later push that adds a bridge such as **M.S.2** <-> **M.A.1** expands the next pull for **M.S.2** to include **M.A.1** as topology-only (no sealed share).

tree fetch refreshes topology without downloading envelopes. **tree publish** remains if you need to replace the document without an envelope.

```
# Person: envelopes plus the slice this pull key is allowed to see
keyquorum --db alice.sqlite relay pull --import --share-file alice.key

# Topology only (no envelopes), including first fetch onto an empty store:
keyquorum tree fetch <key-id>
keyquorum tree fetch --label master
```

6 Hierarchical principals

KeyQuorum implements a hierarchical cryptographic principal model in which organizational ancestry, delegated authority, threshold key reconstruction, and physical key custody are represented as separate but interacting security dimensions. The dotted labels seen throughout this manual — **M**, **M.S**, **M.S.1** — are not just a naming convention. Each one is a *principal*: an entity the system can recognize, place in an ancestry tree, and reason about independently along each of those four dimensions. This section makes that model explicit, because it is what a lot of the behavior in Sections 4, 10, and 11 is actually enforcing.

6.1 What a hierarchical principal is

In access-control and cryptographic-key-management literature, a *hierarchical principal* scheme is any design where identities are arranged in a tree and position in that tree carries meaning: an ancestor has some form of standing over its descendants that a sibling or an unrelated node does not. Familiar examples differ sharply in *what* that standing lets an ancestor do:

- In a **PKI certificate chain**, the hierarchy *is* the trust chain, and a parent's compromise is total: whoever holds a CA's private key can mint a valid certificate for any descendant, so the hierarchy is really one long single point of failure wearing a tree shape.
- In **Hierarchical Identity-Based Encryption (HIBE)**, the hierarchy is a *key-derivation function*: a parent's master secret can compute every descendant's private key directly. Delegation and key escrow are the same operation.
- In **Kerberos realms or Unix group trees**, the hierarchy governs *grants* (who is allowed to do what) but carries no cryptographic material at all.

KeyQuorum's dotted-label tree is closer to the third case than the first two, and that is a deliberate design choice, not an omission. An ancestor label such as **M** or **M.S** can *authorize* specific, narrowly-scoped changes about a descendant — but it can never *derive*, *recover*, or *stand in for* that descendant's private key material. Compromising **M**'s signing key lets an attacker forge authorization letters; it does not, by itself, decrypt anything **M.S.1** holds.

6.2 Four dimensions, four owners

The tree of dotted labels is the substrate all four dimensions are indexed by, but each dimension is a distinct *access structure* — in the secret-sharing sense of the term, a rule for which sets of conditions are authorized — enforced by its own code and its own invariants:

1. **Organizational ancestry.** A pure naming relation: is **M.S** an ancestor of, or equal to, **M.S.2**? This question is answered by string structure alone (dotted-label prefixes), independent of what secret, signature, or device sits at either node. It is the one piece of the model that every other dimension is built on top of.

2. **Delegated authority.** A signature capability: which *registered signing keys* may authorize a change addressed to a given label? The rule (Section 11) is that the signer must be the subject itself, or a dotted-label ancestor whose signing key this store already has on file. A restructure proposed by a non-root label waits for its direct parent’s countersignature; a direct tree update attempted by that same authorizer instead of a proposal is refused outright; and a routine employee reissue by the direct parent stays a single signature. Authority here is the power to *authorize a documented change*, checked fresh against a signature every time — it is never the power to read or reconstruct what the change is about.
3. **Threshold key reconstruction.** A purely mathematical property of the Shamir split tree (Section 7): an M -of- N subset of *sibling* leaf shares reconstructs the secret those siblings were split from. This has nothing to do with ancestry or authority — reconstructing M ’s secret from $M.S$ and $M.A$ ’s shares does not require M ’s signature or cooperation, and M cannot reconstruct it alone by virtue of being the parent label. `unlock_approval = parent` is an optional, additional layer on top of this dimension, not a substitute for it: Shamir’s threshold must still be met, *and* each contributing leaf’s direct parent must sign off.
4. **Physical custody.** A count of distinct hardware devices (Section 4): how many separate device ids back the shares actually consumed by a reconstruction, independent of where those devices’ labels sit in the tree. Two slots on one USB drive count as one device no matter how far apart their labels are in the hierarchy; two key files on two different drives count as two devices even if one label is the other’s direct parent.

This split is visible in the codebase’s own module boundaries, not just in this manual’s organization.

- `private_bridge.rs` owns the dotted-label ancestry test (`is_ancestor_or_self`, `parent_node_label`).
- `org_update.rs` and `authority.rs` own delegated authority.
- The Shamir math for threshold reconstruction lives with the split tree itself.
- `keys.rs` and `device.rs` own the hardware-key registry and physical-device bookkeeping.

A change to one dimension should not require touching the others.

6.3 A worked example

Take $M.S.2$, three labels deep under root M via $M.S$. The four dimensions give four independent, simultaneous answers about that one principal:

Dimension	Answer for $M.S.2$
Ancestry	$M.S$ and M are ancestors; a sibling such as $M.S.3$ is not.
Delegated authority	$M.S.2$ itself, $M.S$, or M may sign a reissue naming $M.S.2$ (Section 11), provided this store already holds a registered signing key for whichever one signs.
Threshold reconstruction	$M.S.2$ is a leaf: it contributes its own share toward reconstructing its <i>parent</i> $M.S$ ’s secret, an M -of- N threshold of $M.S$ ’s children’s shares — not a signature from $M.S$ or M , and not $M.S.2$ ’s share alone unless $M.S$ ’s own threshold is 1.
Physical custody	If <code>minimum_physical_devices</code> is 2, the shares actually consumed toward that threshold must sit on at least two distinct device ids — regardless of which labels those devices happen to hold.

None of these four answers can be derived from another. That independence is the extension KeyQuorum makes to a plain hierarchical-principal model: instead of one tree carrying one kind of authority (as a CA chain or a HIBE key-derivation tree does), the same tree of dotted labels is the shared index for four composed access structures, each satisfied on its own terms, each owned by a different piece of the system, and each capable of tightening independently — raising a threshold, requiring more physical devices, adding a signing-authority ancestor, or reshaping the label tree itself — without weakening the others.

Note

This is also why extending the model with a new relationship should not mean widening `org_update.rs` (the orchestration layer) itself. A new authenticated-update primitive belongs in whichever module owns the table it actually reads or writes — `key_tree.rs` for tree shape, `private_bridge.rs` for the dotted-label hierarchy and bridge rosters, or `keys.rs` for the hardware-key registry — so that the dimension being extended stays legible, and the other three stay exactly as strict as they were before.

7 Quorum-protected files

`access quorum` protects a file against a split tree the same way `split` escrows a standalone secret — `-leaf` builds the tree in the same lock command.

```
keyquorum split --label "escrow demo" --threshold 2 \
  --leaf alice=alice.pub --leaf bob=bob.pub --generate-keys --register
keyquorum tree <key-id>
keyquorum reconstruct <key-id> --share-file alice.key --share-file bob.pub

keyquorum access quorum --state 0 --source ./secret.txt \
  --encrypted-path ./secret.txt.kqenc \
  --leaf alice=alice.pub --leaf bob=bob.pub --register
keyquorum access quorum --status --id <file-id>
keyquorum access quorum --state 1 --id <file-id> \
  --share-file alice.key --share-file bob.pub
```

`<key-id>` and `<file-id>` are printed by `split` / `access quorum -state 0` (“Split key 1” / “Locked file 1”). `-share-file` takes the same key files `generate` wrote (alice.pub / alice.key) or another standard public-key file (PEM, OpenSSH .pub). The private key unwraps every leaf sealed to that hardware key. `tree` still prints leaf node ids for inspection.

7.1 Expiry

`-expires "yyyy-mm-dd hh:mm"` (UTC) gives the locked file a cutoff: the first unlock attempt after that instant deletes the ciphertext and the database row instead of unlocking it.

```
keyquorum access quorum --state 0 --source ./secret.txt \
  --encrypted-path ./secret.txt.kqenc --leaf alice=alice.pub \
  --leaf bob=bob.pub --expires "2026-12-31 23:59"
```

7.2 Verbose unlock

`-state 1 -verbose` prints which shares unwrapped, which subset met the threshold, the physical devices counted toward `minimum_physical_devices`, and any parent approval that was checked. This is the most direct way to confirm *why* an unlock succeeded or failed on a given set of shares.

8 Password-protected files and credentials

Not every secret needs a hardware quorum. `access password` protects a file with a passphrase alone, and `vault` stores ordinary credentials (a username plus a secret) the same way.

```
keyquorum access password --state 0 --source ./secret.txt \
  --encrypted-path ./secret.txt.kqenc
keyquorum access password --state 0 --source ./secret.txt \
  --encrypted-path ./secret-expiring.txt.kqenc --expires "2026-12-31 23:59"
keyquorum access password --state 1 --id 1 --output ./recovered.txt
```

```
keyquorum vault add "Email" --username alice
keyquorum vault get 1
```

Either can also take `-pin` to require a 4-digit PIN, attempt-limited in the style of a FIDO2 PIN, alongside the password. A successful one-time PIN check is cached for one hour; end that window early with, for example:

```
keyquorum pin relock --resource credential --id 1
```

Note

Password-protected files share the same UTC `-expires` cutoff and destructive purge-on-first-touch behavior as quorum-protected files (Section 7).

9 Signatures, export, and sharing

```
keyquorum verify --public-key-file signer.pub --message-file msg.txt \
  --signature-file msg.sig
keyquorum sign --bridge-uid <uid> --node M.A.2 \
  --signing-key-file ma2.sign.key --share-file ma2.key \
  --message-file msg.txt --signature-out msg.kqbs
keyquorum verify --bridge-uid <uid> --as-node M.S.2 \
  --message-file msg.txt --signature-file msg.kqbs

keyquorum export credential 1 --recipient-key-file bob.pub --output cred.kqxb
keyquorum export file 1 --recipient-key-file bob.pub --output file.kqxb

keyquorum share create-file 1 --ttl-seconds 3600 --pin
keyquorum share create-file 1 --expires "2026-12-31 23:59"
keyquorum share redeem-file
```

`verify` works two ways: against a plain public key (`-public-key-file`) for an ordinary Ed25519 signature, or against a private sign bridge's roster (`-bridge-uid` / `-as-node`) for a `.kqbs` artifact — see Section 10.

`export` produces a portable KQXB bundle sealed to a recipient's public key, for a credential or a locked file. Bundles use the same sealed envelope framing as every other letter in this manual; only the recipient's private key can open one.

`-expires` is UTC (`yyyy-mm-dd hh:mm`). After that instant, redeeming a share link, unlocking, or a routine scan deletes the ciphertext from disk and drops the file's database row. `-ttl-seconds` is a separate, relative share-link lifetime and does not by itself remove the underlying file.

Note

`relay push -expires "2026-12-31 23:59"` stamps the same UTC cutoff on each uploaded envelope. An inbox pull skips expired rows and removes them from the mailbox, so the recipient cannot fetch the file after the date.

10 Private sign bridges

A private sign bridge is an N -person group that can co-sign files. Each node is its own storage: `M.A.1` is an employee, `M.A` is the accounting manager, `M` is a cross-department manager (a CXO). A bridge of `M.S.2`, `M.S.3`, and `M.A.2` therefore notifies **five** stores — those three employees plus department managers `M.S` and `M.A`. The CXO is not in that set unless a member is itself a department manager.

Members receive a sealed copy of a shared Ed25519 key (plus salts). Managers receive roster metadata only, so they can track the live standard. This database never keeps another person's sealed secret; `create` and `remove-member` write one `.kqpb envelope` per store.

Note

create and **remove-member** use the same plan-then-commit pattern: they generate every envelope first, write the files, and only then persist the new (or rotated) bridge in this database. Either both land or neither does — a failed write leaves no live row for that change, and a failed commit deletes the envelopes it just wrote, since they would describe a bridge this store never recorded, and **.kqpb** files are never overwritten (leftovers would block the retry). Either way, simply run the command again. There is no separate “redeliver initial packages” command because a failed create never commits.

Each **-member** must already have a registered **signing** public key under that label (**generate -type signing -label M.S.2 -register**). The roster stores that key. **verify** checks the artifact against the roster-bound personal key, not a public key declared only on the signature.

10.1 Envelope shape

Each **.kqpb** is a cryptographic envelope (the same idea as a **KQXB** export bundle): the outside names the recipient’s X25519 public key; the inside is **crypto_box**-sealed so only that store’s encryption private key can open it. A mailbox, USB drop, or email can carry the envelope without being able to read the letter. (**.kqbn** eviction notices are the exception — they are public routing slips, not sealed envelopes.)

outside (anyone can see)	inside (recipient only)
KQPB magic, kind	wrap_salt bridge secret (members)
recipient encryption pub	or roster + salts (managers)
	roster includes each member’s personal signing pub
	+ rotate/destroy auth signature

Five people in the example above means five envelopes, each addressed to a different public key. Operators can copy those files out of band, or push them through the mailbox relay (**keyquorum relay push**) so each store can **relay pull -import** locally.

```
# Each member needs a registered signing public key under their label:
keyquorum generate --type signing --label M.S.2 --register \
  --public-key-out M.S.2.sign.pub > M.S.2.sign.key
# ...same for M.S.3 and M.A.2

# On any machine that can see the tree (and manager encryption pubs):
keyquorum bridge private create 1 \
  --member M.S.2 --member M.S.3 --member M.A.2 \
  --supervisor M.S=SoftwareManager.pub --supervisor M.A=AccountingManager.pub \
  --self M.S.2 --output-dir ./bridge-packages --label eng-acct

# Each other person imports into *their* database:
keyquorum --db ma2.sqlite bridge private import \
  --file ./bridge-packages/M.A.2.kqpb --share-file Accounting2.key

# Sign with the bridge key + the member’s personal signing key:
keyquorum sign --bridge-uid <uid> --node M.A.2 \
  --signing-key-file Accounting2.sign.key --share-file Accounting2.key \
  --message-file report.pdf --signature-out report.kqbs

# Peer verifies with their membership and the artifact:
keyquorum --db ms2.sqlite verify --bridge-uid <uid> --as-node M.S.2 \
  --message-file report.pdf --signature-file report.kqbs
```

10.2 Revocation and rotation

If M.S. revokes M.S.3’s hardware key, that label is dropped from every live private bridge. Ordinary **revoke** (not only **-evict**) prints the notify list and writes a **.kqbn** notice **after** the hardware revoke commits. Remaining members

must rotate — the departed person still holds the old bridge secret. A remaining member then runs:

```
keyquorum bridge private remove-member <uid> --member M.S.3 \
  --node M.S.2 --share-file Software2.key --output-dir ./bridge-packages-rotate
# Copy the new packages to M.S.2, M.A.2, M.S, M.A, and M.S.3
# (or 'keyquorum relay push --dir ./bridge-packages-rotate'). Package
# writers name files by recipient and never overwrite, so reuse the
# original ./bridge-packages here only after clearing it out.
```

A two-person bridge is destroyed when one member is removed.

10.3 Evicting a hardware key

Banning a hardware key is `revoke <hardware-id>`. That always drops pairings and whitelist rows for every live leaf sealed to that token, and drops that label from every live private sign bridge. `-evict` additionally PSS-refreshes survivors of that leaf (`-key-id` / `-node`, or the unique leaf the token backs). Eviction needs a parent threshold of at least 2, and every remaining active sibling must be a hardware-backed leaf — a 1-of- N parent is refused. Binds between survivors stay. `-share-file` is that sibling's actual key file (`.pub` / `.key` from `generate` or `split` `-generate-keys`, or a PEM / OpenSSH public key). A `.pub` file uses a sibling `.key` when present.

```
keyquorum split --label "team escrow" --threshold 2 \
  --leaf alice=alice.pub --leaf bob=bob.pub --leaf carol=carol.pub \
  --generate-keys --register
keyquorum tree <key-id>
keyquorum revoke <carol-hardware-id> --evict \
  --share-file alice.key --share-file bob.pub
# pin a leaf when the token backs more than one:
#   --key-id <key-id> --node carol
```

11 Authenticated updates: reissue and restructure

Replacing someone's token, or changing the shape of the split tree, has to reach every store that held the old picture. Both changes ship as the same sealed `.kqpb` envelope a private bridge uses, so the mailbox routes them without being able to read them — but the letter inside is *signed* by an authorizing label, so each store decides for itself whether to apply it.

11.1 The four-part authorization rule

A store applies an update only when all four of these hold:

- **Addressed here** — the envelope's recipient key is an unrevoked encryption key this store has registered under the label named inside the letter. Re-addressing a letter to another mailbox gets it rejected.
- **Authorized** — the signer is the subject itself or one of its ancestors in the dotted hierarchy (M over M.S over M.S.2), and this store already holds a registered signing key for that label. A peer branch cannot restructure your tree or swap your token.
- **Signed** — Ed25519 over a domain-separated hash that covers every field, including the recipient label and its public key.
- **In order** — a reissue must be exactly one past the last one this store applied for that person; a restructure must carry a public generation strictly greater than the one stored. Replays, stale envelopes, and skipped sequences change nothing.

```
# The authorizing label needs a registered signing key:
keyquorum generate --type signing --label M --register \
  --public-key-out M.sign.pub > M.sign.key

# Restructure: after 'add', 'revoke --evict', or 'bind', announce the new
# shape. Each active leaf gets its own visible slice at the next generation.
# Root (M) is effective immediately. A label with a parent, such as M.S,
```

```
# writes a proposal and waits. Each write below gets its own --output-dir
# and its own push: these can overlap in which leaves they address (a
# proposal for M.S can name the same leaves the root's own restructure
# just did), and package writers never overwrite an existing file.
keyquorum tree restructure 1 --as M --signing-key-file M.sign.key \
  --output-dir ./updates-root
keyquorum relay push --dir ./updates-root

keyquorum tree restructure 1 --as M.S --signing-key-file M.S.sign.key \
  --output-dir ./updates-ms-proposal
keyquorum relay push --dir ./updates-ms-proposal

keyquorum tree countersign 1 --as M --signing-key-file M.sign.key \
  --output-dir ./updates-countersign
keyquorum relay push --dir ./updates-countersign
# the same countersignature from a slot:
# keyquorum tree countersign 1 --as M --device ./usb --slot M \
#   --output-dir ./updates-countersign

# Reissue: M.S.2 lost their token and generated a replacement.
keyquorum reissue --node M.S.2 --key-id 1 \
  --encryption-public-key-file M.S.2.new.pub \
  --as M --signing-key-file M.sign.key --revoke-previous \
  --output-dir ./updates-reissue
keyquorum relay push --dir ./updates-reissue
```

Each store applies these the same way it applies a bridge envelope — the kind byte in the header decides which it is:

```
keyquorum --db M.S.1.sqlite relay pull --import --share-file M.S.1.key
keyquorum --db M.S.1.sqlite bridge private import --file M.S.1.kqpb \
  --share-file M.S.1.key
keyquorum --db M.S.1.sqlite updates # what this store has applied
```

11.2 What a reissue changes

A reissue reaches every store whose own slice named that person, plus every party of every live private bridge they are on — nobody else, since nobody else held the key. It reports that person's tree leaves and bridge roster entries, and drops the leaf's sealed share, which was wrapped to the retired token and cannot be opened by its replacement. Recover it from the quorum, or reseal with `bind -public-key-file`.

Watch out

The shared secret of a private bridge is *not* rotated by a reissue. Run `bridge private remove-member` to roll that generation if the retired token could have been compromised.

The subject's own copy is addressed to the **incoming** encryption key, so their replacement device must have registered it (`generate -register`, or `register`) before importing — which is also what lets it open the letter.

11.3 Restructure vs. publish

`tree restructure` differs from `tree publish` in exactly this way: `publish` replaces a relay document with a store's own view, while a restructure hands each person a slice they can verify the authority for.

A restructure whose authorizer is the root is applied as soon as a store accepts the envelope. A restructure whose authorizer has a parent (M.S under M) is a proposal until that parent runs `tree countersign`; import accepts that change only with the parent's countersignature. A routine employee reissue by that employee's own parent (M.S reissuing M.S.1) stays a single signature.

12 Moving a key between devices

`keyquorum transfer` copies or moves an active identity between two devices that are both open. Each side has its own container and its own database; the global `-db` is not used. Enroll a slot before the first transfer so this device has an active identity for that label.

```
keyquorum transfer enroll --device ./usb --db ./alice.sqlite --label M.S
keyquorum transfer copy \
  --from-device ./usb --from-db ./alice.sqlite \
  --to-device ./usb2 --to-db ./bob.sqlite \
  --label M.S
keyquorum transfer move \
  --from-device ./usb --from-db ./alice.sqlite \
  --to-device ./usb2 --to-db ./bob.sqlite \
  --label M.S --descendants key-only
keyquorum transfer list --db ./bob.sqlite
keyquorum transfer list --db ./alice.sqlite --all
keyquorum transfer recover \
  --from-device ./usb --from-db ./alice.sqlite \
  --to-device ./usb2 --to-db ./bob.sqlite \
  --transaction <hex-id>
```

The identity `id` is stable; the dotted label is only the current place in the hierarchy. Possession on a device is **active** (the slot secret is here), **ghost** (the hierarchy row remains and the secret does not), or **absent**. `transfer list` hides ghosts unless `-all` is set.

- **COPY** leaves the source active and records that the destination may hold a legitimate copy.
- **MOVE** leaves the source row active until the destination has committed and the source slot token is gone. The ghost row is written only after that deletion, so a reported ghost cannot still be opened by `keyquorum-device`. A transfer that stops before the destination commits keeps the usable copy on the source.

`transfer recover` finishes a transfer whose destination already committed, or rolls back one that did not.

`-descendants` selects what travels with the label: **key-only** (the default), **direct-children**, or **all-descendants** (the full subtree). A parent can move without its children, and a child can move while the parent stays. `-as` names the active identity authorizing the transfer and defaults to `-label`.

Note

A ghost keeps hierarchy and provenance and holds no usable private key. It cannot sign, satisfy a quorum, authorize an import, or be exported. An active child under a ghost ancestor stays usable. Ghosts do not authorize an incoming key.

An empty receiver accepts the package. A receiver that already holds active identities accepts an incoming key only when it is a descendant of one of those identities. The same identity `id` with the same public keys reconciles; the same `id` or the same label with different key material is refused.

12.1 Package format and audit

The package magic is `KQTX`. The source device key signs it, and it is bound to the destination device `id`. Replay, tamper, and a bad source are refused. Every attempt is audited without private key material; SQLite stores the transfer state and the audit row. The raw `KQTX` package stays off the mailbox.

12.2 Transferring through the mailbox

When the two devices are not open together, the commands below seal that package, or a slot relocate, into a `.kqpb` letter, and the mailbox stores only that letter.

```
# Bob prepares the receiving side first: a slot to collect into, and a
# published descriptor so relay-finalize can later fetch his verify key.
# 'provision' prints the new slot's encryption and signing public keys;
```

```

# save the printed encryption hex to bob-slot.pub and send it to Alice
# out of band (relay-send needs it before either device is online together).
keyquorum device provision ./usb2 --label recv
keyquorum device publish ./usb2 --url https://relay.example.com

keyquorum device publish ./usb --url https://relay.example.com
keyquorum transfer relay-send \
  --operation move \
  --from-device ./usb --from-db ./alice.sqlite \
  --label M.S \
  --to-device-id <hex-device-id> \
  --recipient-key-file ./bob-slot.pub \
  --url https://relay.example.com
keyquorum transfer relay-collect \
  --to-device ./usb2 --to-db ./bob.sqlite \
  --slot recv \
  --from-device-id <hex-source-id> \
  --url https://relay.example.com
keyquorum transfer relay-finalize \
  --from-device ./usb --from-db ./alice.sqlite \
  --slot M.S \
  --to-device-id <hex-device-id> \
  --url https://relay.example.com
keyquorum device relay-relocate \
  --from ./usb --label M.S \
  --to-device-id <hex-device-id> \
  --recipient-key-file ./bob-slot.pub \
  --url https://relay.example.com
keyquorum device relay-accept ./usb2 --slot recv \
  --url https://relay.example.com
keyquorum device relay-drop ./usb --label M.S \
  --to-device-id <hex-device-id> \
  --relocate-id <hex-relocate-id> \
  --url https://relay.example.com

```

relay-send leaves the source prepared. **COPY** stays active. **MOVE** deletes the source slot token and writes the ghost only when **relay-finalize** checks the destination's signed acknowledgement. **relay-relocate** prints a relocate id and leaves the source slot in place until **relay-drop** checks an acknowledgement signed for that id — an acknowledgement from an earlier relocation of the same slot does not match. **relay-accept** acknowledges a slot that is already installed with the same keys again, so a retry after a failed upload finishes.

The mailbox keeps device letters and acknowledgements for 30 days and never deletes them on acknowledgement. Load a **device.push** key for sends and publishes, and a **device.pull** key bound to the recipient fingerprint for collects, finalizes, and drops. **relay-collect** and **relay-accept** also need **device.push** to post the acknowledgement (**-push-key**, or a stored key of that scope).

13 Sending a file

deliver seals one file to another label. You sign it with your signing key and seal it to the encryption key your store has registered for the recipient. The recipient opens it: that step verifies your signature against the signing key their store holds for you. They then answer with a signed accept or reject, sealed back to you. Letters and answers are ordinary **.kqpb** envelopes that **relay push** / **relay pull** carry.

```

keyquorum deliver send --file report.pdf --to M.A --as M.S.1 \
  --slot ./usb=M.S.1 --push
keyquorum --db david.sqlite relay pull --output-dir ./mail
keyquorum --db david.sqlite deliver open --file ./mail/7.kqpb \
  --slot ./usb=M.A --save-dir ./received --push-ack

# The acknowledgement is sealed back to the sender -- pull it into the

```

```
# sender's own store (a different mailbox than David's ./mail above)
# before answering it.
keyquorum relay pull --output-dir ./mail
keyquorum deliver ack --file ./mail/8.kqpb --slot ./usb=M.S.1
```

`-output-dir` / `-ack-dir` write the envelope to disk instead of (or as well as) `-push` / `-push-ack`. `-reject` refuses the file and says so in the answer.

14 The mailbox relay

The hosted mailbox carries sealed `.kqpb` envelopes and public-tree slices. It indexes packages by the recipient fingerprint in the outer header and never unseals them; wrapped shares and private keys stay on the device. Your provider gives you a URL and an API key — you do not run the mailbox or mint keys yourself. Official `loadkey` / `relay` commands authenticate that host with a KeyQuorum-signed provider certificate before sending a bearer.

```
export KEYQUORUM_RELAY_URL=https://relay.example.com
# Load once; omit the key so it is prompted (stays out of shell history).
keyquorum loadkey --url https://relay.example.com
keyquorum relay push --dir ./bridge-packages
keyquorum relay pull --output-dir ./inbox
keyquorum --db alice.sqlite relay pull --import --share-file alice.key
# --api-key still works for scripts and is stored after a successful check.
keyquorum relay push --dir ./bridge-packages --api-key "$PUSH_KEY"
```

`loadkey` first verifies the relay's KeyQuorum-signed identity, then checks the key with the mailbox, then stores the key hash and a sealed copy of the bearer in the personal database. Later `relay` / `tree fetch` commands repeat that identity check and re-check the hash before using the key. An optional signed revocation list can be pointed at with `KEYQUORUM_PROVIDER_KRL`.

`relay push` also uploads every public tree in `-db` and `merges` it into the mailbox (unrelated nodes stay put). `relay pull` merges the returned slices into `-db` (then `-import` opens envelopes). `tree fetch` syncs topology without an envelope. Remote mailboxes must be `https://`; `http://` is accepted only for loopback.

14.1 The device mailbox

Device copy, move, and relocate (Section 12) use a second mailbox on the same host. `device.push` stores a sealed letter and publishes a device's public descriptor (device id, verify key, and slot public keys, signed by the device key). `device.pull` is bound to one recipient fingerprint, the same way `inbox.pull` is, and reads only that fingerprint's letters. A missing bearer is rejected, and a key of the wrong scope is rejected — the host does not mint keys over HTTP. Your provider issues `device.push` and `device.pull` the same way it issues inbox keys; `loadkey` stores them. The host refuses a raw KQTX package and never unseals a letter. Bridge import does not read this mailbox, and device letters are not accepted into the bridge inbox.

14.2 Recovering from a lost key or a missed pull

If a key is lost or rotated, load the replacement your provider issues. Envelopes already delivered are unchanged.

```
keyquorum relay pull --after <id> --output-dir ./inbox
# or, to unseal them into --db directly:
# keyquorum relay pull --after <id> --import --share-file alice.key
```

replays anything not yet downloaded; `bridge private import` still rejects stale generations, so replaying an old envelope by mistake changes nothing.

15 Security model

This project handles cryptographic key material and encrypted user data directly. This section summarizes the trust boundaries described throughout the manual so they are visible in one place.

Security

Never commit private keys, tokens, secrets, API key bearers, provider certificates, revocation lists, device descriptors (`device.kq`, `device.skey`), slot tokens (`*.kqst`), or plaintext copies of protected files to a repository. See `.gitignore` for the patterns already excluded. Compiling with `-features provider` does not make a host a trusted KeyQuorum provider.

15.1 What the mailbox can and cannot see

The hosted mailbox cannot decrypt `.kqpb` envelopes and must not be given wrapped shares or private keys. It stores the canonical *public* tree as JSON documents — labels, fingerprints, public keys, policy. Sending envelopes with `relay push` updates those documents from the sender's `-db`. Pulling returns a sliced copy for the pull-key fingerprint, which the CLI translates into local SQLite. Personal devices load a bearer with `keyquorum loadkey` (or `-api-key` once); they keep the hash and a sealed copy of the bearer in the owner-only org database.

Recover a lost bearer by loading the replacement your provider issues. Recover a missed update by pulling again and importing on the device that holds the matching decryption key.

15.2 Custody, quorum, and delegation, at a glance

- A key file with no container placement is its own device; distinct `-share-file` keys are distinct physical devices, and presenting the same key twice still counts once (Section 7, Section 3).
- Hardware custody requires each consumed Shamir share to sit on its own device id; logical custody lets several slots on one container meet a threshold together, but the container still counts as one device (Section 3).
- `unlock_approval = parent` layers a required parent signature on top of Shamir and the device count; it is opt-in, not a replacement for either (Section 3).
- A non-root `tree restructure` is a proposal until the parent countersigns; a direct tree update from that authorizer is refused; a routine employee reissue by the direct parent stays a single signature (Section 10, Section 9).
- A ghost identity keeps hierarchy and provenance but holds no usable private key: it cannot sign, satisfy a quorum, authorize an import, or be exported (Section 12).

15.3 Envelopes and authenticity

Every sealed letter in this manual — a private-bridge package, an authenticated update, an export bundle, a delivered file, a device transfer letter — shares the same shape: the outside names a recipient public key in the clear, the inside is sealed so only that recipient's private key can open it, and where the letter carries an authorization decision (an authenticated update, a delivery, a device transfer acknowledgement) it is additionally *signed* by whoever is authorizing that decision, checked against a key the opening store already has on file. A mailbox that carries these letters can route them by their outer fingerprint without ever being able to read or forge what is inside.

16 File formats quick reference

Every on-disk and on-wire artifact this manual mentions has its own magic bytes, so a store can tell at a glance what it is holding without trusting a file extension.

Magic	Extension	What it is
KQPB	.kqpb	Sealed PACKAGE envelope: private-bridge letters, authenticated updates, device transfer/relocate letters, file delivery letters and acks.
KQXB	.kqxb	Sealed EXPORT_BUNDLE : a portable credential or file export.
KQBS	.kqbs	Signature artifact from sign against a private bridge roster.
KQDV	device.kq	Signed device descriptor, verified against device.skey .
KQST	*.kqst	A slot token, sealing one logical identity to a device id.
KQTX	—	Device transfer package, signed by the source device, bound to a destination device id. Never stored raw on the mailbox.
—	.kqbn	Eviction notice — a public routing slip, not a sealed envelope.

Note

KQPB and KQXB share one sealed-envelope framing (magic, version, kind byte, recipient X25519 public key, sealed length); they are two *formats* of the same codec, not two independent designs. Device copy, move, and relocate letters are additional **PACKAGE** kind bytes under KQPB, not a separate format.

16.1 Roadmap

Private-key custody today is a key file (one key, one device) or a **keyquorum-device** container (one directory, many passphrase-wrapped slots). **generate** still prints a private key once and does not write it. Real USB token protocols are not implemented; a container is a directory, not an OS partition.

- **Persisted private-key custody** for **generate** beyond the key file and the slot token (for example, an OS keychain).
- **import** of password-vault / locked-file **export** bundles. The bundle format and encoder are already final; private-bridge **.kqpb** import is already implemented.

17 Contributing

AI coding agents working in this repository should read the relevant instructions file for their tool: **CLAUDE.md** for Claude, **AGENTS.md** for Codex and other agent tooling, and **.cursorrules** for Cursor.

18 License

Licensed under the MIT License. See **LICENSE** in the repository root for details.